

Oversight of Reporting Breaches of Data Protection

Date: 31-08-2023

Decision

Public Authorities

Serious Criticism

Supervision / Self-initiated Case

Unintentional Disclosure

Unauthorized Access

Report of Breach of Data Protection

The Data Protection Authority has conducted 16 planned inspections focusing on municipalities' and banks' handling of breaches of data protection. The Data Protection Authority found reason to express criticism in two cases.

Journal Number: 2021-423-0244.

Roskilde Municipality was among the public authorities that the Data Protection Authority selected for oversight in the spring of 2021 under the General Data Protection Regulation [1] and the Data Protection Act [2].

The Data Protection Authority's oversight was a written inspection that focused on whether Roskilde Municipality reports and documents breaches of data protection in accordance with Article 33, paragraph 1, and Article 33, paragraph 5 of the General Data Protection Regulation, including the municipality's processes for handling and recording breaches of data protection. The oversight was based on an assessment of samples among unreported breaches as well as information about guidelines, procedures, and training activities, etc.

The oversight was announced to Roskilde Municipality by letter dated June 21, 2021, and the municipality was simultaneously requested to answer a number of questions. The Data Protection Authority informed about the background for the oversight, stating that a review of the oversight's cases regarding reports of breaches of data protection revealed that Roskilde Municipality had reported significantly fewer breaches of data protection per inhabitant in the municipality than other municipalities in Denmark.

By letter dated September 13, 2021, Roskilde Municipality sent a statement in which the municipality responded to the Data Protection Authority's questions. Roskilde Municipality's response was also accompanied by a number of documents, including process descriptions that the municipality uses to comply with Article 33 of the General Data Protection Regulation.

Summary

In the summer and autumn of 2021, the Data Protection Authority initiated written inspections of the handling of breaches of data protection by eight larger municipalities and eight larger banks.

The inspections were organized so that the municipalities and banks were divided into two groups – those that had reported the most and the fewest breaches in relation to the municipality's population and the number of employees in the bank.

"One of the new things that came with GDPR over five years ago was that data controllers, as a general rule, must report all breaches of data protection to the Data Protection Authority within 72 hours, and they must also internally document all breaches of data protection, regardless of whether they need to be reported to the Data Protection Authority or not. Additionally, there has been an increased focus on what companies and authorities need to consider when customers' or citizens' information is mishandled by mistake," says Vibeke Dyssemark Thomsen, Chief Consultant at the Data Protection Authority, and continues: "This can, for example, lead to the need to implement new or additional security measures to reduce the risk of further breaches. Therefore, we have now conducted a service review of the area, where we have looked at the procedures and taken some samples. The conclusion is broadly that the 16 selected municipalities and banks seem to have the right focus on complying with the rules."

Group with the Most Reported Breaches

For the group with the most reported breaches, the inspections focused, among other things, on whether the municipalities and banks had taken appropriate security measures to reduce the number

of breaches of data protection, where there had been unauthorized disclosure of personal data in connection with sending information to, among others, citizens, authorities, etc., including in relation to citizens with name and address protection and financial information.

Compliance with the rules on appropriate processing security will normally entail that:

The data controller must ensure that information about data subjects, including particularly confidential and sensitive personal data, does not come to the knowledge of unauthorized persons. In this regard, the data controller must ensure that all employees in the organization are, to the necessary extent, familiar with any internal procedures for handling personal data, including in relation to sending personal data to, among others, citizens, authorities, etc. Procedures, guidelines, workflows, technical security measures, etc. are continuously updated or introduced, including as a result of identified breaches of data protection.

The Data Protection Authority found on the basis of the available information that all data controllers had taken appropriate security measures. In its assessment, the Data Protection Authority emphasized that:

Procedures, etc. had been developed and activities had been carried out to educate employees in data protection, including to ensure that they are aware that there should be no unintentional disclosure of personal data to an incorrect recipient.

They have considered and continuously implemented both technical and organizational measures following past breaches of data protection to avoid similar breaches.

There is a strong focus on avoiding unintentional disclosure of confidential information, which is supported both by business processes, ongoing guidance, etc., and systematic measures, etc.

****The Group with the Fewest Reported Breaches****

For the group with the fewest reported breaches, the inspections focused on whether municipalities and banks report and document breaches of personal data security in accordance with the requirements of the General Data Protection Regulation (GDPR), including their processes for handling and recording breaches of personal data security.

The Data Protection Authority stated in these cases that it is the Authority's opinion that compliance with the rules that breaches of personal data security must, as a rule, be reported to the Data Protection Authority within 72 hours entails that:

1. The data controller must establish appropriate procedures and guidelines to ensure that breaches are detected and handled correctly.
2. In this context, the data controller must ensure that all employees in the organization are familiar with internal procedures for handling breaches of personal data security to the necessary extent, and that relevant employees can identify, handle, and assess breaches of personal data security.

The Data Protection Authority found that all data controllers, overall, have adopted appropriate procedures and guidelines, etc., and have implemented appropriate training activities that can support compliance with the requirements of the GDPR regarding the reporting of breaches of personal data security. Thus, they can ensure that breaches of personal data security are captured within the organization so that these can be assessed to determine whether the breach should be reported to the Data Protection Authority, as well as to document the breaches, including the reasons for not reporting them to the Data Protection Authority.

However, the Data Protection Authority noted in relation to all inspections that the Authority had not had the opportunity as part of the inspection to specifically assess whether all relevant employees have completed the relevant training activities, and that the Authority is not familiar with the full content of the training material, including the content of, for example, ongoing awareness initiatives.

Furthermore, the Data Protection Authority stated that the rule that the data controller must document all breaches of personal data security, including the actual circumstances of the breach, its effects, and the remedial measures taken, must ensure that the Data Protection Authority can verify that the provision regarding the reporting of breaches of personal data security has been complied with. The data controllers should therefore document their reasons for all significant decisions made as a result of the breach. This is particularly relevant if the data controller, after assessing the breach, concludes

that it does not need to be reported to the Data Protection Authority. The documentation should, in relation to this decision, include a detailed explanation of why the data controller believes that the breach is unlikely to result in a risk to the rights and freedoms of natural persons.

****Criticism in Two Cases****

As mentioned, there has been pronounced criticism in two of the cases – specifically regarding two municipalities that did not document all breaches of personal data security.

In one case, the Data Protection Authority expressed serious criticism of Roskilde Municipality for not documenting how many breaches of personal data security the municipality has identified in the period from May 25, 2018, to September 2019, and that the municipality cannot document whether the recorded security incidents since September 2019 constitute actual breaches of personal data security.

In the other case, the Data Protection Authority criticized Frederikshavn Municipality for not documenting how many breaches of personal data security the municipality has identified in 2018. The Data Protection Authority notes that the list of breaches – in addition to serving as documentation to the Data Protection Authority – should also be used by the data controller to gain an overview of which breaches typically occur in the organization, and based on this, to consider whether, from a risk assessment, there is a need to implement new or supplementary measures to avoid or further reduce the risk of additional breaches. It also appears from the received consultation responses that several of the data controllers actively use the lists for this purpose.

****1. Decision****

After reviewing the submitted material, the Data Protection Authority finds grounds to express serious criticism of Roskilde Municipality for not documenting how many breaches of personal data security the municipality has identified in the period from May 25, 2018, to September 2019, and that the municipality cannot document whether the recorded security incidents since September 2019 constitute actual breaches of personal data security, cf. Article 33(5) of the General Data Protection Regulation.

Furthermore, the Data Protection Authority finds that Roskilde Municipality has overall adopted appropriate procedures and guidelines and has implemented appropriate training activities to correctly capture and handle breaches of personal data security, cf. Article 33 of the General Data Protection Regulation.

Below follows a detailed review of the information that has emerged in connection with the inspection, and a justification for the Data Protection Authority's decision.

****2. Justification for the Data Protection Authority's Decision****

****2.1. Relevant Legal Provisions****

A breach of personal data security is defined in Article 4(12) of the General Data Protection Regulation,

be defined as breaches of personal data security that do not require notification to the supervisory authority. The third incident involved a situation where a document containing personal data was mistakenly sent to an external party. The municipality has acknowledged that this incident should have been reported to the supervisory authority.

2.4. Conclusion

In conclusion, the Data Protection Authority emphasizes the importance of proper documentation and timely reporting of personal data breaches as mandated by the General Data Protection Regulation. The failure to document and report breaches not only undermines compliance with the regulation but also poses risks to the rights and freedoms of individuals whose data may be affected. The Data Protection Authority urges Roskilde Municipality to implement robust procedures and training to ensure that all employees are aware of their responsibilities regarding data protection and breach reporting.

3. Recommendations

The Data Protection Authority recommends that Roskilde Municipality:

1. Establish clear procedures for identifying, documenting, and reporting personal data breaches in

accordance with Article 33 of the GDPR.

2. Provide training for all employees on data protection and the importance of timely reporting of breaches.
3. Regularly review and update its data protection policies and procedures to ensure compliance with applicable regulations.
4. Conduct audits of past incidents to assess whether they were appropriately documented and reported.

By taking these steps, Roskilde Municipality can enhance its data protection practices and better safeguard the personal data of individuals.

characterized as a breach of personal data security, cf. Article 4, No. 12 of the data protection regulation, but that these are not subject to the obligation to report.

The Data Protection Authority thus finds no basis for overriding the assessment that it must be deemed unlikely that the relevant breaches entail a risk to the rights and freedoms of natural persons, cf. Article 33, paragraph 1.

The Data Protection Authority can thus agree that data controllers may, depending on the circumstances, refrain from reporting breaches as described in the second incident, but the authority notes that this is based on a specific assessment of the incident, including, among other things, who the recipients of the personal data are and the nature of the personal data involved in the breach, etc.

The third incident concerned the submission of information by five citizens to one of the municipality's mailboxes, from which the mail was not redistributed internally in the municipality until the mailbox was accidentally discovered. The Data Protection Authority can concur with Roskilde Municipality's own subsequent assessment that the incident does not constitute a breach of personal data security and is therefore also not subject to the obligation to report to the authority. The Data Protection Authority has emphasized that the reported incident does not constitute a breach of established security measures that have led to accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to personal data that has been transmitted, stored, or otherwise processed, cf. the definition in Article 4, paragraph 1, No. 12 of the data protection regulation.

2.4. Procedures and Training of Employees

It appears from the statement of September 13, 2021, and the attached appendices, that Roskilde Municipality has, among other things, established procedures for how and to whom breaches of personal data security should be reported internally in the municipality, whom employees can contact with questions about breaches, and who is responsible for handling and assessing breaches as well as reporting to the Data Protection Authority.

It further appears that Roskilde Municipality has developed procedures and conducted activities aimed at training employees in data protection, including e-learning courses, so that they will be able to identify and potentially handle breaches of personal data security.

Regarding the criteria included in Roskilde Municipality's assessment of whether a breach of personal data security should be reported to the Data Protection Authority, Roskilde Municipality has referred to the fact that employees have been informed about examples of security incidents, and that it is recommended that all breaches concerning sensitive personal data and personal identification numbers are always reported to the Data Protection Authority.

Based on the submitted material, including information about the unreported breaches from 2021 – despite the lack of registration of breaches in the period from May 25, 2018, to September 2019 – the Data Protection Authority's immediate assessment is that Roskilde Municipality has overall adopted appropriate procedures and guidelines, etc., and has conducted appropriate training activities that can support compliance with the requirements in Article 33 of the data protection regulation, and which can ensure that breaches of personal data security are captured within the organization, so that these can be assessed to determine whether the breach should be reported to the Data Protection Authority, as well as documentation of the breaches can be made, including, among other things, the justification for

not reporting them to the Data Protection Authority.

It is noted that the Data Protection Authority has not had the opportunity, as part of the supervision, to specifically determine whether all relevant employees have completed the relevant training activities, and that the authority is not familiar with the full content of the training material, including the content of, for example, ongoing awareness initiatives.

[1] Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons in relation to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation)

[2] Act No. 502 of May 23, 2018, on supplementary provisions to the regulation on the protection of natural persons in relation to the processing of personal data and on the free movement of such data. (Data Protection Act)